ShivaZen

Documento de Requisitos

Versao 3.0 - Abril 2026

Sistema de Gestao para Clinica de Estetica

Sumario

1. Introducao
2. Requisitos Funcionais
  2.1 Autenticacao e Controle de Acesso
  2.2 Gestao de Clientes
  2.3 Agendamento
  2.4 Prontuario e Anamnese
  2.5 Procedimentos e Servicos
  2.6 Pacotes
  2.7 Financeiro
  2.8 NPS e Avaliacoes
  2.9 Comunicacao (WhatsApp)
  2.10 Lista de Espera
  2.11 Relatorios e Exportacao
  2.12 Configuracao do Sistema
3. Requisitos Nao Funcionais
  3.1 Seguranca
  3.2 Performance
  3.3 Usabilidade
  3.4 Infraestrutura
4. Regras de Negocio
5. Modelo de Dados
6. Pendencias

1. Introducao

O ShivaZen e um sistema web de gestao para clinicas de estetica, desenvolvido em Django 5.2 com PostgreSQL. O sistema contempla agendamento online, prontuario eletronico, gestao de pacotes, comunicacao via WhatsApp Business API, controle financeiro e conformidade com a LGPD.

Este documento especifica os requisitos funcionais, nao funcionais e regras de negocio que regem o comportamento do sistema.

2. Requisitos Funcionais

2.1 Autenticacao e Controle de Acesso

RF-01 - Login por e-mail e senha

O sistema deve autenticar usuarios (profissionais e administradores) utilizando e-mail e senha com hashing seguro (PBKDF2/bcrypt).

RF-02 - Perfis de acesso (RBAC)

O sistema deve suportar perfis configuráveis (Administrador, Profissional, Recepcionista) com permissoes granulares por funcionalidade.

RF-03 - Verificacao de telefone para clientes

Clientes devem verificar seu telefone via codigo de 6 digitos enviado por SMS ou WhatsApp antes de agendar.

RF-04 - Protecao contra brute-force

O sistema deve aplicar rate limiting (10 requisicoes/minuto por IP) em endpoints criticos de autenticacao e agendamento.

RF-05 - Criacao de superusuario com perfil Administrador

O comando createsuperuser deve vincular automaticamente o perfil Administrador ao usuario criado.

2.2 Gestao de Clientes

RF-06 - Cadastro de cliente

O sistema deve permitir o cadastro de clientes com nome, telefone, e-mail, data de nascimento e endereco.

RF-07 - Controle de faltas

O sistema deve registrar faltas e permitir bloqueio automatico apos 3 faltas consecutivas (configuravel).

RF-08 - Reset de faltas

O administrador deve poder resetar o contador de faltas de um cliente.

RF-09 - Listagem e busca de clientes

O painel administrativo deve listar clientes com busca por nome, telefone e status.

2.3 Agendamento

RF-10 - Agendamento online pelo cliente

O cliente deve poder agendar um horario selecionando profissional, procedimento, data e hora disponiveis.

RF-11 - Confirmacao de presenca via link

O sistema deve enviar link de confirmacao via WhatsApp. O cliente confirma clicando no link com token unico.

RF-12 - Cancelamento de agendamento

O cliente deve poder cancelar um agendamento via link com token seguro (nao apenas telefone + ID).

RF-13 - Bloqueio de horarios na agenda

O profissional ou admin deve poder bloquear horarios especificos (ferias, almoco, manutencao).

RF-14 - Verificacao de conflitos de horario

O sistema deve impedir agendamentos sobrepostos para o mesmo profissional no mesmo horario.

RF-15 - Lembrete automatico de consulta

O sistema deve enviar lembrete via WhatsApp 24h antes do atendimento agendado (via Celery Beat).

RF-16 - Reagendamento

O sistema deve permitir reagendar um atendimento mantendo o historico do agendamento original.

2.4 Prontuario e Anamnese

RF-17 - Ficha de anamnese

O sistema deve armazenar dados de anamnese do cliente: alergias, condicoes medicas, medicamentos e contraindicacoes.

RF-18 - Evolucao clinica por sessao

Cada atendimento deve permitir registro de evolucao clinica com observacoes, fotos e procedimentos realizados.

RF-19 - Historico de atendimentos

O prontuario deve exibir o historico completo de atendimentos do cliente em ordem cronologica.

2.5 Procedimentos e Servicos

RF-20 - Cadastro de procedimentos

O admin deve poder cadastrar procedimentos com nome, descricao, duracao estimada, preco e categoria.

RF-21 - Categorias de procedimentos

Os procedimentos devem ser organizados por categoria (Harmonizacao Facial, Corporal, Skin Care, etc).

RF-22 - Associacao profissional-procedimento

O sistema deve permitir definir quais profissionais realizam quais procedimentos.

2.6 Pacotes

RF-23 - Criacao de pacotes

O admin deve poder criar pacotes com N sessoes de procedimentos especificos, preco total e validade.

RF-24 - Venda de pacote ao cliente

O sistema deve registrar a venda de um pacote a um cliente com data de inicio e calculo de data de expiracao.

RF-25 - Controle de sessoes do pacote

Cada sessao utilizada deve ser registrada com data, profissional e observacoes. Pacote finaliza ao completar todas as sessoes.

RF-26 - Expiracao automatica de pacotes

Pacotes expirados (data_validade ultrapassada) devem ser marcados automaticamente como expirados via tarefa agendada.

RF-27 - Alerta de pacotes expirando

O sistema deve alertar (via WhatsApp) clientes cujos pacotes expiram em 7 dias.

2.7 Financeiro

RF-28 - Registro de pagamento por atendimento

O sistema deve registrar o pagamento de cada atendimento com valor, forma de pagamento e status.

RF-29 - Formas de pagamento

O sistema deve suportar: dinheiro, PIX, cartao de credito, cartao de debito e pacote pre-pago.

RF-30 - Relatorio financeiro

O admin deve visualizar relatorio de faturamento por periodo com filtros por profissional e procedimento.

2.8 NPS e Avaliacoes

RF-31 - Envio automatico de pesquisa NPS

Apos cada atendimento concluido, o sistema deve enviar pesquisa NPS via WhatsApp (escala 0-10).

RF-32 - Classificacao NPS

O sistema deve classificar respostas: Detratores (0-6), Neutros (7-8), Promotores (9-10).

RF-33 - Alerta de detrator

Respostas de detratores (nota <= 6) devem gerar alerta ao administrador via tarefa diaria.

RF-34 - Coleta de feedback textual

O sistema deve permitir que o cliente adicione um comentario apos a nota NPS.

2.9 Comunicacao (WhatsApp)

RF-35 - Webhook WhatsApp Business API

O sistema deve receber e processar mensagens via webhook com verificacao HMAC-SHA256 da assinatura Meta.

RF-36 - Envio de mensagens template

O sistema deve enviar mensagens via WhatsApp Business API para confirmacoes, lembretes e pesquisa NPS.

RF-37 - Notificacao de novo agendamento

O profissional deve receber notificacao via WhatsApp quando um novo agendamento for criado em sua agenda.

2.10 Lista de Espera

RF-38 - Inscricao em lista de espera

O cliente deve poder se inscrever na lista de espera para um profissional/procedimento quando nao ha horario disponivel.

RF-39 - Notificacao de vaga

Quando um horario for liberado, o sistema deve notificar o proximo cliente da lista de espera.

2.11 Relatorios e Exportacao

RF-40 - Dashboard administrativo

O painel deve exibir metricas: agendamentos do dia, faturamento mensal, taxa de faltas e NPS medio.

RF-41 - Exportacao para Excel

O admin deve poder exportar relatorios de atendimentos e faturamento em formato Excel (.xlsx).

RF-42 - Relatorio de ocupacao por profissional

O sistema deve gerar relatorio de taxa de ocupacao da agenda por profissional e periodo.

2.12 Configuracao do Sistema

RF-43 - Horario de funcionamento

O admin deve configurar horario de funcionamento da clinica por dia da semana.

RF-44 - Configuracao de dias nao uteis

O sistema deve permitir configurar feriados e dias sem atendimento.

RF-45 - Seed de dados iniciais

O sistema deve ter endpoint protegido (autenticacao + token) para carregar dados iniciais (perfis, funcionalidades).

RF-46 - Termos de uso e politica de privacidade

O sistema deve exibir termos de uso e politica de privacidade com versionamento e aceite registrado (LGPD).

RF-47 - Consentimento por procedimento

Antes de procedimentos invasivos, o sistema deve coletar assinatura digital do termo de consentimento.

RF-48 - Pagina institucional publica

O sistema deve ter paginas publicas: home, servicos, equipe, galeria, depoimentos e contato.

RF-49 - Tema e identidade visual configuravel

O sistema deve permitir configuracao de logo, cores e informacoes de contato da clinica.

3. Requisitos Nao Funcionais

3.1 Seguranca

RNF-01 - Hashing de senhas

Senhas devem ser armazenadas com PBKDF2-SHA256 (padrao Django) com salt aleatorio.

RNF-02 - HTTPS obrigatorio em producao

Toda comunicacao em producao deve usar TLS 1.2+. SECURE_SSL_REDIRECT e cookies seguros devem estar ativos.

RNF-03 - Protecao CSRF

Todos os formularios POST devem incluir token CSRF. Excecao apenas para webhooks com verificacao HMAC.

RNF-04 - Content-Security-Policy

Headers CSP devem restringir fontes de scripts e estilos a dominios confiáveis (CDNs utilizados + self).

RNF-05 - Rate limiting fail-closed

Em caso de falha do backend de rate limiting, o sistema deve negar a requisicao (fail-closed).

RNF-06 - Variaveis sensiveis em ambiente

SECRET_KEY, credenciais de API e tokens devem estar em variaveis de ambiente, nunca no codigo-fonte.

RNF-07 - Verificacao de webhook HMAC-SHA256

Webhooks da Meta/WhatsApp devem ter assinatura verificada via HMAC-SHA256 antes de processar o payload.

3.2 Performance

RNF-08 - Indices no banco de dados

Campos frequentemente consultados (status, data_hora_inicio, telefone, cliente+status) devem ter indices.

RNF-09 - Queries otimizadas

Listagens devem usar select_related/prefetch_related para evitar N+1 queries.

RNF-10 - Paginacao

Todas as listagens com mais de 50 registros devem usar paginacao (Django Paginator).

RNF-11 - Tarefas assincronas

Operacoes demoradas (envio de WhatsApp, relatorios, NPS) devem ser executadas via Celery.

3.3 Usabilidade

RNF-12 - Responsividade

Todas as paginas devem ser responsivas (mobile-first) usando Bootstrap 5.

RNF-13 - Acessibilidade basica

Formularios devem ter labels, contraste minimo WCAG AA e navegacao por teclado.

RNF-14 - Feedback ao usuario

Acoes do usuario devem ter feedback visual (toast, alert) indicando sucesso ou erro.

RNF-15 - Tempo de resposta

Paginas devem carregar em menos de 3 segundos em conexao 3G. Assets estaticos servidos via WhiteNoise com cache.

3.4 Infraestrutura

RNF-16 - Deploy em Railway

O sistema deve ser implantado na Railway com PostgreSQL, Redis e worker Celery.

RNF-17 - Celery Beat com 7 tarefas agendadas

O scheduler deve executar: lembretes, confirmacoes, NPS, alertas de detrator, pacotes e limpeza de status.

RNF-18 - Arquivos estaticos via WhiteNoise

Em producao, arquivos estaticos devem ser servidos pelo WhiteNoise sem necessidade de Nginx.

RNF-19 - Backup automatico do banco

O banco PostgreSQL deve ter backup diario automatico configurado na Railway.

RNF-20 - Logs estruturados

O sistema deve usar logging do Python com niveis adequados (INFO para operacoes, WARNING para anomalias, ERROR para falhas).

RNF-21 - Migracao de banco versionada

Todas as alteracoes de schema devem ser feitas via Django migrations, nunca SQL direto em producao.

RNF-22 - CI/CD com testes automatizados

O pipeline deve executar testes automatizados antes de cada deploy. Cobertura minima desejada: 80%.

4. Regras de Negocio

RN-01 - Limite de faltas

Cliente com 3 ou mais faltas consecutivas e bloqueado para novos agendamentos ate reset manual pelo admin.

RN-02 - Conflito de horario

Nao e permitido agendar dois atendimentos para o mesmo profissional no mesmo horario.

RN-03 - Confirmacao obrigatoria

Atendimentos nao confirmados ate 2h antes sao marcados automaticamente como nao confirmados.

RN-04 - Finalizacao de pacote

Um pacote e finalizado quando todas as sessoes forem realizadas ou quando atingir a data de validade.

RN-05 - Expiracao de pacote

Pacotes com data de validade ultrapassada sao marcados como expirados automaticamente (diariamente as 00:30).

RN-06 - NPS: escala 0-10

Detratores: 0-6 | Neutros: 7-8 | Promotores: 9-10. Respostas fora dessa faixa sao rejeitadas.

RN-07 - Preco nao negativo

Valores de procedimentos, pacotes e pagamentos devem ser >= 0. Enforced via CHECK constraint no banco.

RN-08 - Termos versionados (LGPD)

Cada versao de termo e imutavel apos publicacao. Novos termos geram nova versao, mantendo historico de aceites.

RN-09 - Consentimento por procedimento

Procedimentos invasivos exigem assinatura de termo de consentimento antes da realizacao.

RN-10 - Unicidade de agendamento

Um cliente nao pode ter dois agendamentos ativos (Agendado ou Confirmado) no mesmo horario.

RN-11 - Profissional vinculado a usuario

Todo profissional deve estar vinculado a um usuario do sistema com perfil adequado para acesso ao painel.

5. Modelo de Dados

O banco de dados possui 30 tabelas organizadas em 8 dominios:

Dominio	Tabelas
Acesso e Permissoes	Usuario, Perfil, Funcionalidade, PerfilFuncionalidade
Catalogo	Procedimento, Profissional, ProfissionalProcedimento
Agendamento	Atendimento, BloqueioAgenda, ListaEspera
Prontuario	Anamnese, EvolucaoClinica, AnexoEvolucao, FotoAntesPosterior
Pacotes	Pacote, ItemPacote, PacoteCliente, SessaoPacote
Financeiro	Pagamento
Comunicacao	NotificacaoWhatsApp, PesquisaNPS
Legal/LGPD	VersaoTermo, AceitePrivacidade, AssinaturaTermoProcedimento

O DDL completo com CHECK constraints, indices e comentarios esta disponivel em docs/ddl_banco_dados.txt.

6. Pendencias

Itens restantes para conclusao do sistema:

Seguranca (4 itens)

- Cancelamento de agendamento com token seguro (anti-IDOR)
- Content-Security-Policy header
- Envio real de codigo de verificacao via SMS/WhatsApp
- Remover codigo_debug da verificacao de telefone

Frontend (7 itens)

- Termos de Uso: substituir Lorem Ipsum
- Politica de Privacidade: substituir Lorem Ipsum
- Pagina de Depoimentos/Avaliacoes
- Galeria da Clinica
- Pagina Equipe/Profissionais
- Pagina de Especialidades
- Detalhe de Servico

Backend (11 itens)

- Produtos/Dermocosmeticos (model ou catalogo)
- Prontuario: formularios de anamnese
- Termos de Consentimento: fluxo de assinatura
- Pacotes: CRUD admin e venda
- Lista de Espera: interface
- NPS via Web (link email/SMS)
- Recuperacao de senha
- Bloqueio de Agenda: implementar endpoints
- CRUD de Procedimentos
- Detalhe/Edicao de Cliente
- Paginacao real com Django Paginator

Qualidade de Codigo (11 itens)

- Trocar wildcard imports por imports explicitos
- Centralizar numero WhatsApp placeholder
- Remover nomes de procedimentos hardcoded
- Corrigir N+1 queries no prontuario
- Corrigir N+1 no exportar_relatorio_excel
- Resolver django-jazzmin (instalar ou remover)
- Renomear static/assents/ para static/assets/
- Atualizar jQuery para 3.7+
- Remover JS morto em baserodape.html

- Registrar Django Admin URL ou remover admin.py
- Implementar testes automatizados